

SentinelAPI — Explained in Plain English

A tool that finds hidden security holes in websites, automatically

AMIHACKS 2026 — Track C (Deep-Tech)

September 24, 2026

“We built a robot that finds a website’s hidden security holes automatically — before a hacker does.”

1. The Problem, in One Minute

Apps and websites talk to servers through “doors” called **APIs**. Every time you log in, check a balance, or open a profile, your app is knocking on one of these doors. When a door is built carelessly, two things go wrong:

1. **The open door.** The server hands over *someone else’s* data when you ask — because nobody checked *who* is asking.
2. **The oversharing door.** The server sends back *too much* — passwords, card numbers, private details the app never needed.

Hackers find these mistakes every day. Companies usually notice only *after* the damage is done, because checking by hand is slow and expensive.

2. What We Built

SentinelAPI is an *automatic security inspector*. You point it at an app’s doors, and it tells you exactly which ones are unsafe — in plain words, with a one-line proof, so anyone can act on it.

In one sentence

It creates two imaginary users, checks whether one can see the other’s secrets, and checks whether the server is sharing more than it promised.

3. How It Works — Five Simple Steps

1. **We built a practice app** with known flaws, like a training dummy for the inspector to test itself on.
2. **The inspector creates two imaginary users** — Alice and Bob.

3. **It pretends to be Alice and asks for Bob's stuff.** If the server says “*sure, here's Bob's data*” — that's a red flag. We call it the *open-door* problem.
4. **It compares the promise with reality.** The server's own rulebook says what it will share; the inspector checks what it *actually* shares. Extra secrets — passwords, card numbers — are another red flag. We call it the *oversharing* problem.
5. **It writes a report.** Every problem gets a colour badge (**red** = serious, **orange** = important) plus a copy-paste command that proves it.

4. What Makes It New

We test, we don't guess

Most scanners throw random junk at a server and hope something breaks. We do something smarter: we create **two real users** and check whether one can see the other's data. That is a *real test*, not a guess.

We use the server's own rulebook

Every server has a “rulebook” (a file describing what it should share). We compare what the server *promised* against what it actually does. The difference between promise and reality is where the leak is.

Every finding comes with proof

No vague warnings. Each problem includes a copy-paste command anyone can run to see the leak with their own eyes — so there are *no false alarms*.

Runs anywhere, costs nothing

The whole thing works offline with free, open tools — no paid services, no cloud, no internet needed for the demo.

5. The Tech Stack, in Plain Terms

Tool	What it does for us
Python + FastAPI	The practice app, and the “brain” of the inspector
Go	A second, faster copy of the brain (single file, no setup)
OpenAPI	The server's rulebook the inspector reads
HTML + CSS + Three.js	The clean report page with colour badges and a 3D background

6. The Results

We tested the inspector on **two practice apps** with 24 hidden problems in total. It found **all 24**, and raised **zero** false alarms. In measuring terms: **100% precision, 100% recall**. In plain words: it catches everything real and never cries wolf.

7. Jargon, Translated

The technical words, explained simply:

Term	What it actually means
API	The “door” an app uses to ask a server for data
BOLA / IDOR	The “open door” bug — seeing other people’s data
OpenAPI	The server’s written “rulebook” of what it should share
Differential testing	Creating two users and comparing what each can see
Broken authentication	The door works with <i>no</i> key at all
Privilege escalation	A normal user getting <i>admin</i> powers they shouldn’t have
Mass assignment	The server accepting extra fields it was never asked for
SSRF guard	A safety lock so our tool can’t be abused to attack other servers
Precision / Recall	How often it’s right vs. how many real bugs it misses

The result: a tool that finds security holes automatically, explains them in plain words, and proves them — before a hacker does.